传智杯 · AI WEB 网页开发挑战赛

消费CT · SpendCT

AI BILL CHECKUP & CONSUMPTION INSIGHTS

「 给你的账单做一次体检 」

赛道：AI WEB 网页开发挑战赛（track id=10037）

作品形态：AI 账单体检与消费洞察平台 · Web 应用

开发团队：独立开发（1 人队）

提交日期：2026 年 11 月

账单数据全程不出浏览器 —— 这是产品承诺，也是技术架构的第一性原理

目录 CONTENTS

1 项目背景与痛点 3

2 产品概述与核心功能 4

3 竞品对比与差异化 6

4 系统架构 7

5 隐私与数据安全（亮点） 8

6 六阶段体检管线 9

7 智能能力：LLM 与 RAG 11

8 核心页面展示 12

9 技术验证 15

10 工程规范与研发流程 16

11 展望与里程碑 17

结语 18

附：项目仓库 / 在线演示 / 开发日志 / 设计文档索引 18

本文档为参赛说明摘要（≤30 页），完整设计与契约见仓库 docs/ 目录 8 份设计文档（01 架构 / 02 数据隐私 / 03 Agent 流水线 / 04 RAG-MCP / 05 UIUX / 06 路线图 / 07 权威契约 / 08 功能扩展）。

01 项目背景与痛点

WHY

年轻人的钱不是「记不清」，而是「看不见问题」。微信、支付宝、银行卡、信用卡的账单散落在多个入口；自动续费在几十块钱的量级上悄悄扣款；深夜冲动消费事后无感。传统记账工具回答了「钱花在哪」，却没有回答「账单有什么问题、下一步怎么办」。

痛点 四类高频消费困境

痛点	典型场景	SpendCT 的回答
账单零散	微信 / 支付宝 / 银行卡多入口，月末对账靠翻聊天记录	多格式账单一键导入，浏览器内解析合并去重
订阅陷阱	自动续费低额高频，注销入口隐蔽，用户到退款时才察觉	确定性规则扫描连续扣费，附下次扣费倒计时与取消指引
冲动消费	深夜下单、直播抢购，事后复盘无抓手	异常检测阶段标记深夜 / 大额 / 高频异常，量化损失
预算失守	记账 App「记录有余、诊断不足」，预算形同虚设	12 类目预算环 + 超支贴士 + 下月预测 + 一句话记账

定位 目标用户与产品主张

目标用户：大学生与年轻上班族——消费场景丰富、财务经验不足、对隐私敏感、习惯「先看结论」。

> 定位一句话：**不是又一个记账工具，而是「体检 + 处方」**——像体检报告一样，先出结论与证据，再给可执行的改善动作。

- **结果先于对话**：AI 先把体检结论写成带证据的洞察卡流（可审阅、可存档），用户带着具体问题点卡片追问，而不是从空白聊天窗开始；
- **结论可溯源**：每张洞察卡带置信度、图表证据与引用（聚合 SQL / 订阅规则 / 案例库 / 工具），低置信度结论自动挂起（宁缺毋滥）；
- **隐私可见**：账单明细只在浏览器内计算，服务端只转发脱敏聚合摘要，数据可见性对照表公开在产品内。

02 产品概述与核心功能

WHAT

SpendCT 把微信、支付宝导出的账单 CSV 拖进浏览器，一条六阶段流水线自动完成**清洗 → 消费画像 → 异常检测 → 订阅陷阱扫描 → 环比归因 → 年度报告**，产出可确认、可质疑、可深挖的消费洞察卡。全过程实时可见、可暂停、可断点续跑。

功能 功能总览

模块	说明
六阶段体检	清洗 → 画像 → 异常 → 订阅 → 归因 → 年度，流式事件实时可见（20 类协议事件），支持暂停 / 恢复 / 断点续跑
洞察卡流	每条结论带置信度、图表证据、SQL / RAG 引用，可确认 / 质疑 / 收藏 / 深挖；低置信度结论自动挂起
订阅雷达	确定性规则（同商户 ≥3 笔、间隔 25–40 天、金额 ±1% 容差）揪出连续扣费，附下次扣费倒计时与取消指引
预算中心	12 类目预算环 + 超支贴士 + 下月预测 + 一句话快速记账
年度报告	健康指数 + 四项对标指标 + 滚动叙事 + 1080×1920 海报导出
知识课堂	60 条可核验案例（订阅陷阱 / 预付风险 / 消费维权 / 学生权益），附法条与官方来源
本地账户	IndexedDB 账户体系（PBKDF2-SHA256 加盐哈希），注册 / 登录 / 个人中心 / 成就段位
数据主权	账单 CSV / JSON 一键导出、一键删除；数据可见性对照表公开在 /privacy

动线 用户旅程

① 导入
微信 / 支付宝 CSV 拖入
或一键加载示例账单

→

② 体检
六阶段流水线流式运行
思考过程实时可见

→

③ 洞察
洞察卡流 + 筛选 + 收藏
点卡片锚点追问

→

④ 行动
订阅取消指引 / 预算调整
年度报告海报分享



图 1　首页 —— 三句话讲清产品：账单体检、数据不出浏览器、示例账单即点即用

03 竞品对比与差异化

WHERE WE DIFFER

产品	目标用户	数据来源	交互范式	隐私模型	AI 能力
Rocket Money	美国订阅管理人群	银行 Plaid 连接	订阅清单 + 建议（半自动）	云端全量账单	订阅识别 / 砍价代理
Cleo	欧美年轻人	银行连接	聊天窗（AI 人设对话）	云端	对话式财务问答
随手记	国内记账人群	手动 + 模板导入	账本列表	本地 + 云同步	基础分类
钱迹	极简记账用户	手动为主	账本 + 报表	本地	无
SpendCT（本作）	**大学生 / 年轻上班族**	**微信 / 支付宝 CSV + 截图**	**AI 先体检 → 洞察卡流 → 锚点追问**	**明细不出浏览器，LLM 仅见聚合摘要**	**六阶段流水线 + 订阅雷达 + RAG**

对手三选一：要么云端全量账单（隐私弱），要么聊天窗（结论不可审阅），要么没有 AI。SpendCT 在**交互范式**与**隐私模型**两个维度同时不同：

- **交互范式**：结果先于对话——AI 先把结论写成卡片流（可审阅、可存档、可纠错），用户带着具体问题点卡片追问，而不是从空白聊天窗开始；
- **隐私模型**：账单明细只在浏览器内计算（DuckDB-WASM），大模型只看到聚合后的摘要数字，任何一步都不需要上传账单原文。

竞品信息整理自各产品官网（2026-10），来源链接与完整对照表见 docs/competitor-benchmark.md。

04 系统架构

HOW IT WORKS



分层 技术选型

层	选型	职责
展示层	Next.js 16（App Router）+ React 19 + TypeScript（strict）+ Tailwind 4（CSS-first 令牌）+ ECharts 6 + Framer Motion	13 个路由页、暗色模式（图表经 CSS 变量桥接）、键盘快捷键
状态层	Zustand + TanStack Query + IndexedDB（idb）	跨页内存态（仅数据集哈希 + 运行摘要，不落行数据）
计算层	DuckDB-WASM 1.32（自托管于 public/duckdb，断网可用）	浏览器内解析、聚合、预计算——隐私架构的地基
智能层	DeepSeek-V3 / SiliconFlow Qwen / GLM-4V-Flash / Transformers.js（local-tfjs）	任务路由 + 三级降级链 + mock/live 双模式（零密钥可演示）
安全层	SQL 窄文法白名单（7 原因码）、金额全链路整数分、check-secrets 钩子	LLM 生成 SQL 只读可拦截、密钥永不入库
工程层	Vitest（单测）+ Playwright（e2e）+ tsgo + ESLint，依赖精确锁版本	契约先行、分层测试、提交规范（见第 10 章）

05 隐私与数据安全（亮点）

PRIVACY BY ARCHITECTURE

传统账单工具需要把账单上传云端才能做分析。SpendCT 的隐私不是「承诺不偷看」，而是**架构上就没有上传通道**：解析、聚合、体检全部发生在浏览器内的 DuckDB-WASM 列式引擎里。

对照表 每一步的数据可见性

环节	数据形态	去向
账单导入	原始 CSV（含交易明细）	仅浏览器内存，不落盘、不上传
六阶段聚合	SQL 分组聚合结果（9 预计算表 / 13 视图）	浏览器内
LLM 叙事 / 建议	聚合统计值（金额分箱脱敏 + 数据集哈希）	服务端转发，不存任何请求日志
字段映射 AI 兜底	表头 + 至多 1 条样本行（≤6KB 截断）	仅在探测链全失败且用户确认后发送
账户凭据	PBKDF2-SHA256 加盐哈希（15 万次迭代）	IndexedDB 本地
断点 / 缓存键	阶段进度 + 数据集哈希	localStorage 仅存键（红线：不落任何行数据与聚合明细）

红线 三条不可逾越的约束（07 权威契约 §17）

- **localStorage 红线**：不存任何行数据与聚合明细，只存哈希与进度键——刷新后数据随内存库消失，由断点条引导重新体检；
- **密钥红线**：API 密钥只走环境变量（.env.example 提供模板），`NEXT_PUBLIC_` 前缀禁用，pre-commit 的 check-secrets 钩子扫描历史防泄漏；
- **数据主权**：账单 CSV / JSON 一键导出、一键删除；删除后 IndexedDB 不留痕；数据可见性对照表直接公开在 /privacy 页面。

账户 本地账户模式

账户体系完全本地化：注册 / 登录 / 会话全部在 IndexedDB 完成（PBKDF2-SHA256 加盐哈希），演示账户 **demo / demo123** 即开即用；个人中心提供成就段位、数据导出与删除入口。选择本地账户而非云端账户，是「账单数据不出浏览器」承诺的自然延伸——**没有账户服务器，就不存在账户数据泄露面。**

06 六阶段体检管线

THE PIPELINE

阶段	职责	确定性依据	典型产物卡
① **清洗 clean**	去重、退款标记、格式统一	交易指纹（sha256）+ 去重规则	数据质量卡（行数 / 覆盖期 / 重复率）
② **画像 profile**	消费结构与习惯画像	类目 / 商户 / 月度三张统计表	类目占比、最大支出商户、周末消费特征
③ **异常 anomaly**	深夜、大额、高频异常	分位数阈值 + 日汇总表	深夜消费总量、异常峰值事件
④ **订阅 subscription**	连续扣费订阅识别	同商户 ≥3 笔、间隔 25–40 天、金额 ±1% 容差	订阅清单 + 年化金额 + 取消优先级
⑤ **归因 attribution**	环比变化归因	月度环比（MoM）统计表	支出涨跌归因到类目 / 商户
⑥ **年度 annual**	健康指数与年度总结	年度汇总表 + 四项对标	健康指数、年度叙事、报告海报

协议 状态机与事件流（spendct协议@2）

管线是一台严格的状态机：每阶段 **pending → running → succeeded / skipped / failed**，阶段失败发 error 事件并降级继续（不中断整次体检）；运行可暂停（中止保留已产出卡）与断点续跑（从最近断点阶段重跑，阶段结果确定性保证产出一致）。

事件组	事件（共 20 类）
运行边界（4）	run:start · run:complete · abort · checkpoint:saved
阶段（5）	stage:start · stage:thinking · stage:evidence · stage:complete · stage:skipped
洞察卡（3）	card:delta · card:complete · card:withheld
LLM（2）	llm:degraded · llm:repair
RAG / 工具 / 反思 / 缓存（6）	rag:retrieved · tool:start · tool:end · reflect:result · cache:hit · error（8 错误码判别联合）

闸门 SQL 白名单与发布闸门

- **确定性主体**：体检结论全部来自代码常量的白名单 SQL（9 预计算表 + 13 视图），LLM 只负责叙事与建议——结论可复现、可审计；
- **SQL 白名单**：追问场景 LLM 生成的 SQL 必须通过窄文法预检（7 原因码逐条解释拒绝理由），执行层行数复检 + 3s 超时中断，只读连接无写权限；

- **发布闸门（reflect）**：每张卡自检 confidence ≥ 0.6、阶段证据 ≥ 2 行、统计值非全零，全部通过才 published，否则 withheld 并明示原因——**宁缺毋滥**，低置信度结论不抢高位视线。

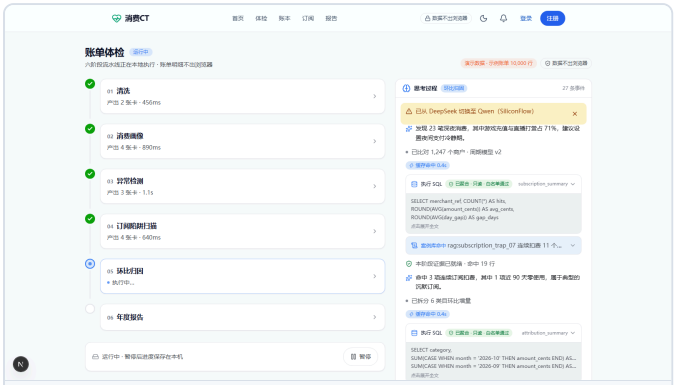


图 2　体检运行 —— 六阶段步进器 + 思考过程面板（SQL / 证据 / RAG / 降级逐条可见）

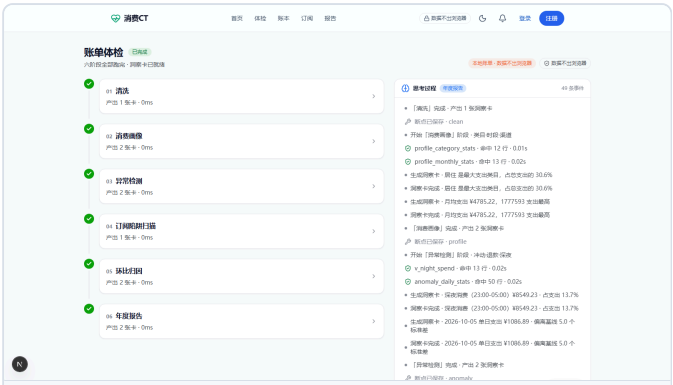


图 3　真实管线运行 —— 浏览器内 DuckDB-WASM 真实执行，事件流实时渲染

07 智能能力：LLM 与 RAG

THE BRAIN

智能层遵循一条原则：**模型只做「锦上添花」，不做「一锤定音」**。体检结论由确定性 SQL 给出，LLM 负责把聚合数字写成有洞察的叙事、生成可执行的建议、回答锚点追问——任何模型失败都不影响体检结果本身。

路由 任务级模型路由与三级降级链

任务	主模型	降级链
六阶段叙事 / 洞察卡叙事	deepseek	qwen → 确定性模板叙事 + llm:degraded 横幅
锚点追问 plan / summarize	deepseek	qwen → 内置 DRILL_TEMPLATES 模板
字段映射 / 表头猜测	qwen	规则映射 → AI 兜底（用户确认后）
截图 OCR（后续）	glm4v	GLM-4V-Flash 网关，失败提示重试

- **mock / live 双模式**：三个密钥全空时服务端强制 mock 模式——演示、测试、断网全链路可用；配置密钥后切 live；
- **指数退避**：上游限流时按退避策略切换，过程通过 llm:degraded 事件在思考面板如实展示（不伪造进度）；
- **反思自检**：卡片叙事经 L2 裁判模型自检（reflect 事件），自检不过即挂起。

RAG 本地案例检索与可溯源引用

- **案例库 60 条**：订阅陷阱、预付风险、消费维权、学生权益四类，每条带法条出处与官方来源链接，检索默认走本地 TF-IDF（零依赖、公网可部署）；
- **MCP 工具**：和风天气工具（雨天外卖溢价提醒等场景），契约化调用；
- **引用可溯源**：每张卡的引用五类形态——数据表 / 视图（sql）、规则（rule）、案例（rag）、工具（tool）、个人锚点（personal），UI 中逐条可展开核对。

08 核心页面展示

THE PRODUCT

8.1 账户体系



图 4　登录 —— 沉浸式卡片 + 信任条（数据不出浏览器承诺）

图 5　注册 —— 密码强度实时反馈 + 本地账户模式说明

8.2 账单上传与字段映射

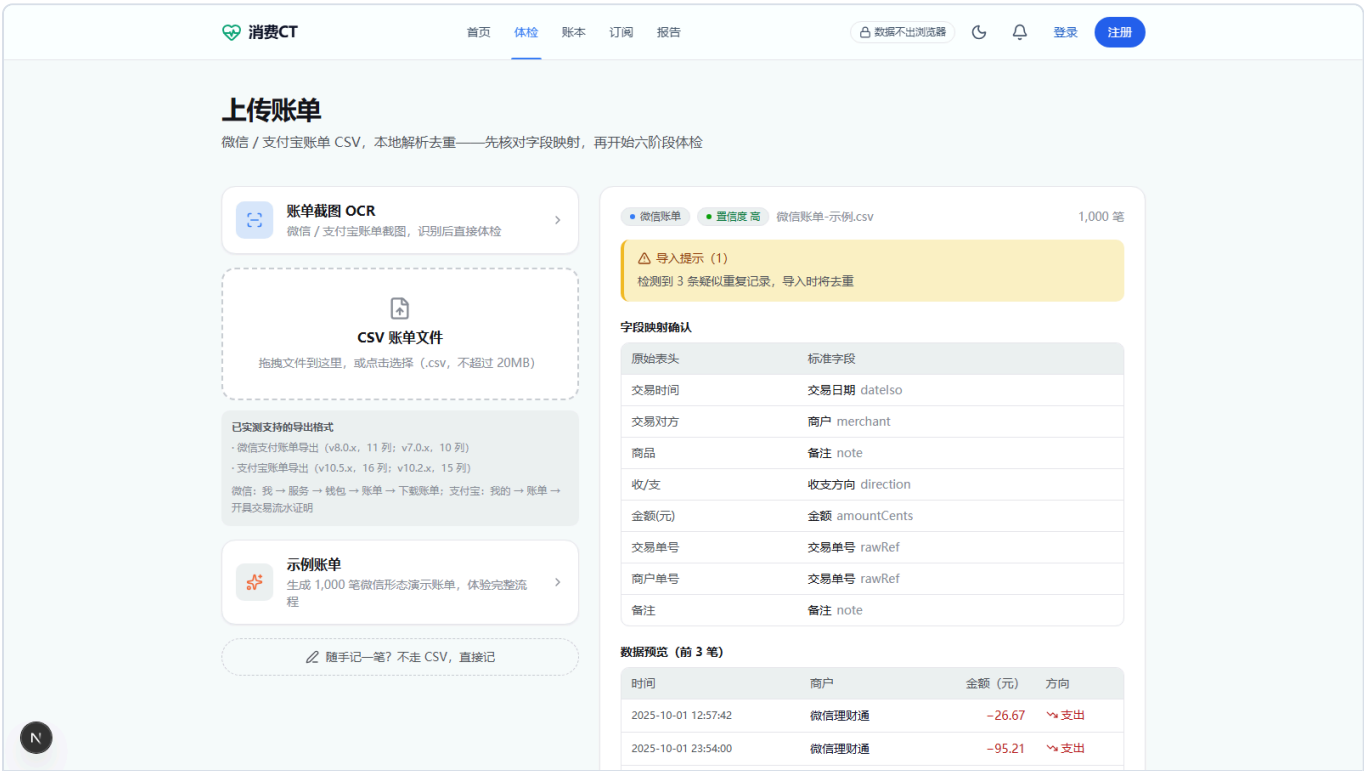


图 6　上传 —— 三种入口（截图 OCR / CSV / 示例账单）· 置信度评估 · 字段映射确认 · 重复记录提示，全流程本地解析

8.3 洞察卡流

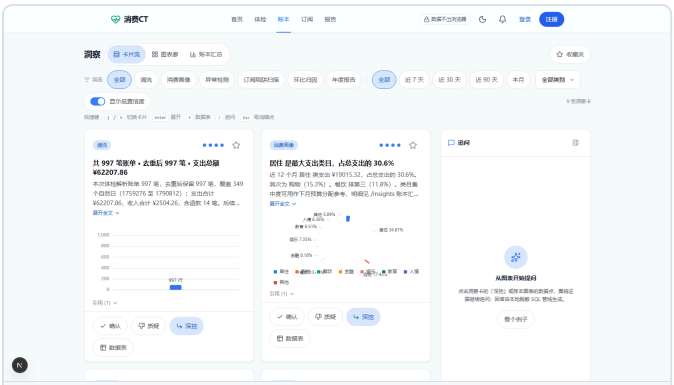


图 7　洞察卡流（真实体检结果） —— 阶段 / 置信度 / 日期 / 类别四维筛选，图表证据 + 引用 + 确认 / 质疑 / 深挖



图 8　暗色模式 —— 图表颜色经 CSS 变量桥接，暗色切换零 JS 主题表

8.4 订阅雷达 • 年度报告 • 预算中心



图 9　订阅雷达 —— 连续扣费清单 + 下次扣费倒计时 + 取消指引

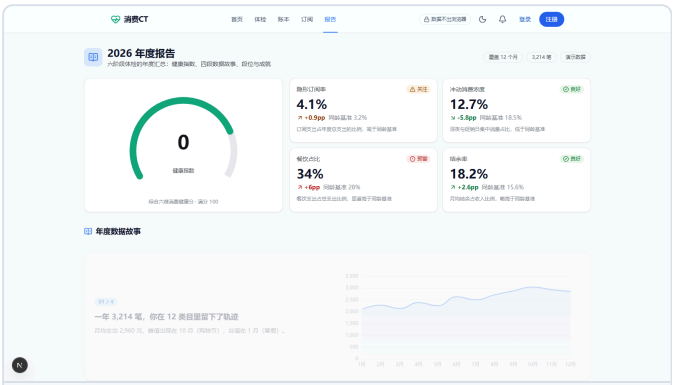


图 10　年度报告 —— 健康指数 + 四项对标 + 滚动叙事

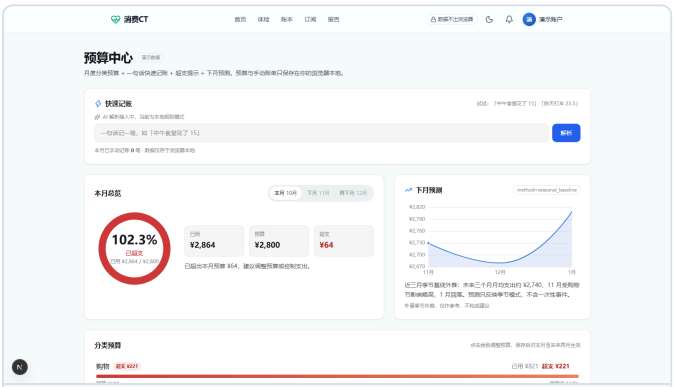


图 11　预算中心 —— 12 类目预算环 + 超支贴士 + 下月预测

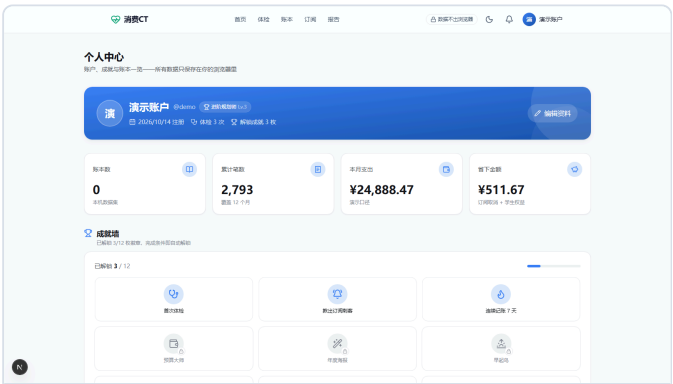


图 12　个人中心 —— 成就段位 + 数据导出 / 删除（数据主权入口）

8.5 设置 • 课堂 • 隐私

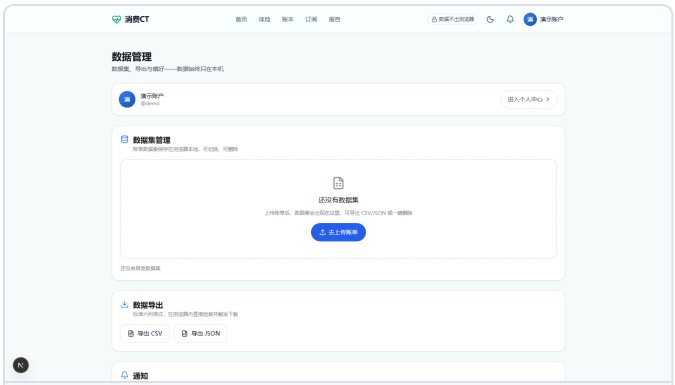


图 13　设置 —— 账户安全 / 通知偏好 / 数据管理



图 14　知识课堂 —— 60 条可核验案例，法条与官方来源可点开

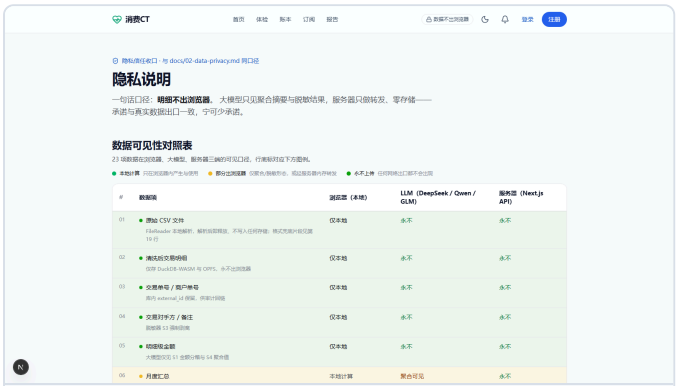


图 15　隐私页 —— 数据可见性对照表公开在产品内，「隐私可见」的落地页

09 技术验证

EVIDENCE

基准 DuckDB-WASM 浏览器内性能（1 万行账单档）

指标	验收阈值	实测（Chromium）	判定
WASM 冷加载	< 4000 ms	874 ms	**通过（余量 4.6×）**
WASM 热加载	< 1500 ms	784 ms	**通过（余量 1.9×）**
1 万行导入 + 聚合	< 2000 ms	456 ms	**通过（余量 4.4×）**
内存占用	< 400 MB	10.1 MB	**通过（余量 40×）**
压力档（10 万行）导入 + 聚合	—（扩展参考）	657 ms	**通过**

口径：与正式管线同源加载自托管 /duckdb/ 产物（mvp wasm + worker），聚合结果逐类目校验无丢行；对照组 Edge 155 同档全过。复现：docs/benchmarks.md + scripts/run-spike-benchmark.mjs。

测试 分层测试矩阵

层	数量	覆盖
单元测试（Vitest）	**158 用例 / 10 文件**	SQL 白名单、账户、导入清洗、事件协议、管线引擎、卡片 schema、运行桥、LLM 层
端到端（Playwright）	**15 用例**	13 页冒烟（0 console error）+ 示例账单全动线（上传 → 真实管线 → 洞察真实卡，32.2s）+ 账户登录
静态质量	**0 错误**	tsgo 全量类型检查、ESLint、生产构建 17 路由（14 静态 + 2 API）

关键设计验证：订阅规则在真实 DuckDB 引擎上命中 / 排除断言通过（demo 数据集含 3 个订阅商户周期扣费）；引擎单测用 fake conn 驱动全部 20 类事件与 8 错误码路径，不依赖 wasm 环境。

10 工程规范与研发流程

CRAFT

- **契约先行**：07 权威契约是单一事实源（阶段清单 / 事件协议 / DDL / SQL 白名单 / 发布闸门全部逐字落地并有单测钉死），设计文档与实现冲突时以契约为准；
- **提交规范**：`<type>(<scope>): 描述`（feat / test / docs / fix…），提交历史即开发叙事，配合 docs/devlog/ 逐日开发日志；
- **锁版本依赖**：全部依赖精确版本（无 ^），自托管 DuckDB-WASM 产物入库，postinstall 自动同步——评审环境断网也能完整复现；
- **演示控制台**：按 `?` 键呼出（重放流水线 / 跳最后阶段 / 注入错误 / 暗色切换 / 断网模拟 / 恢复断点），为评审演示提供确定性兜底；
- **安全工程化**：密钥只走环境变量 + check-secrets 钩子；上传文件大小 / 类型双校验；`?next` 回跳参数白名单消毒；金额全链路整数分（浮点不进库）。

流程 三天冲刺节奏（实际执行）

日期	目标	产出
D1 • 10/13	应用框架层	13 路由页 + 本地账户体系 + 全局壳（暗色 / 移动底栏）+ DuckDB 服务层 + 演示控制台
D2 • 10/14	核心管线全链路	数据 schema / 事件协议 / 六阶段引擎 / LLM 层 + 六页面真实接线 + e2e 验收套件固化
D3 • 10/15	收尾与交付物	全动线手工验收、本文档汇编、演示视频、部署、README / env 模板复核

11 展望与里程碑

WHAT'S NEXT

里程碑	目标	要点
M1 • 上线内测	公网可访问 + 真实用户账单	Vercel 部署、live 模型接入、反馈闭环（确认 / 质疑沉淀进评测集）
M2 • 多账户与 OCR	覆盖更多账单形态	截图 OCR（GLM-4V-Flash）、多账户合并（家庭账本）、账单比对
M3 • 订阅代理	从「识别」到「代办」	订阅比价与砍价代理、自动提醒、一键退订指引打通

扩展 功能扩展清单（节选）

- **账单合并**：情侣 / 室友共同账单的合并体检与 AA 分摊；
- **AI 预算教练**：基于历史画像的预算方案生成与周度复盘；
- **小票 OCR**：线下消费凭证识别入账，覆盖无电子账单场景；
- **社区案例贡献**：用户贡献订阅陷阱案例，RAG 案例库众包增长。

12 结语

> 消费CT 想做的，是让每一个年轻人的账单都值得被认真对待——**体检出问题，处方给动作，数据留本地。**

从「账单零散」到「体检 + 处方」，从「云上分析」到「明细不出浏览器」，从「空白聊天窗」到「可审阅的洞察卡流」——SpendCT 在交互范式与隐私模型两个维度上给出了自己的答案。项目的每一行代码、每一条契约、每一个测试，都记录在公开仓库的提交历史与开发日志里。

感谢评委的时间与关注。

附录 仓库与文档索引

项	内容
仓库	公开仓库（完整提交历史）· MIT 许可
在线演示	Vercel 部署（零密钥 mock 模式，演示账户 demo / demo123）
环境模板	.env.example（密钥全空，标注 07 契约 §12 唯一清单）
设计文档	docs/01 架构 · 02 数据隐私 · 03 Agent 流水线 · 04 RAG-MCP · 05 UIUX · 06 路线图 · 07 权威契约 · 08 功能扩展
工程证据	docs/benchmarks.md（性能基准）· docs/devlog/（开发日志）· tests/unit + tests/e2e（测试矩阵）
演示视频	5-8 分钟 · 1080p（docs/demo-script.md 剧本 S1-S8）